CX Research 02 — Catalogues, Business Rules & Access Governance for Non-Technical Users

Research date: 2026-08-31. Sources: vendor product docs (Atlan, Collibra, Alation, Microsoft Purview, Databricks, Google Dataplex, Select Star, Immuta, dbt, Cube, Camunda, Monte Carlo, Great Expectations, Microsoft Entra, SailPoint, Okta) plus UK GSS statistical disclosure guidance. Quoted strings are copied verbatim from those pages. Everything marked [SYNTHESIS] is my own inference for Spiff, not a vendor fact.

---

1. Data catalogues — how a dataset is presented

1.1 Atlan — the "asset profile"

Source: https://docs.atlan.com/product/capabilities/discovery/concepts/what-are-asset-profiles

Atlan's canonical object is the asset profile. The overview carries technical name and alias, row and column counts, connection, description, owner, lineage view, related assets, and a certification status of "verified, draft, or deprecated" — three states, not a binary. The left rail is a fixed tab set: Overview, Columns, Relations, Usage, Lineage, Fact-Dim Relations, Activity, Resources, Queries, Requests, Properties, Integrations, plus custom-metadata tabs. Two details matter for Spiff:

- Activity is described as "a changelog for the asset" — provenance is a first-class tab, not buried in an admin screen.
- Requests is a tab on the asset itself, filterable by status. Asking for something (access, a description, a term link) happens in context and its history stays visible.
- The README section "provides contextual information about the asset" — a crowdsourced, free-text human explanation sitting alongside the machine metadata.

Header actions: user-activity avatars with view counts, a star/bookmark, a query dropdown, copy-link, Slack/Teams buttons, and a 3-dot menu for announcements.

Access control is bundled into personas — "A persona scopes what a team sees and can do in Atlan. It bundles the users and groups on a team, the policies that govern what they can access, and the display preferences that shape their view of the catalog." Add a user, "they inherit the persona's access and view immediately." Purposes are the complementary tag-based mechanism. (https://docs.atlan.com/product/capabilities/governance/access-control/concepts/what-are-personas)

1.2 Collibra — the data basket

Source: https://productresources.collibra.com/docs/collibra/latest/Content/Catalog/DataSets/ta_request-access-to-data-set.htm

Collibra models access request as shopping. Users "Add to Data Basket" from search, the catalog, or a Data Marketplace preview; the basket icon in the toolbar shows the collected asset cards; users then "Check out Data Basket". If Data Privacy is on, the requester must "select the Purpose that describes the business case for which you are requesting access to the data." Then "the Request Assets Access workflow starts" and — critically — "All data owners must approve the request before you can access the assets." Status is tracked on the Access Requests page. The metaphor is doing real work: batching, a reviewable cart, an explicit purpose, and multi-owner approval.

1.3 Alation — trust flags

Source: https://docs.alation.com/en/latest/welcome/BestPractices/UseTrustFlagstoProceedwithConfidence.html

Alation's trust model is three flags — Endorsement, Warning, Deprecation — set by roles including Catalog Admin and Steward, surfaced as visual indicators in search results and on the object page so users can judge reliability before querying. The significant design choice is that warning is a distinct state from deprecated: "this is risky right now" is different from "this is retired."

1.4 Microsoft Purview — data products and access policies

Sources: https://learn.microsoft.com/en-us/purview/unified-catalog-data-products · https://learn.microsoft.com/en-us/purview/unified-catalog-data-product-access-policies

A data product is "a group of data assets, such as tables, files, and Power BI reports, with a defined use case that you can share with other users" — "a business concept with a name, description, owners, and most importantly a list of associated data assets." Fields: name, description, owners, associated assets, governance domain ("a data product is managed by a single governance domain"), glossary terms, access policy, and business health controls/OKRs.

The request flow is the most fully specified of any vendor I found. Consumer selects the request access button; the form shows Permitted access (usage purposes — "Three purposes are provided by default"), Approval requirements, Attestations (including a "copies of the data are permitted" checkbox), and terms of use. Approval is tiered and sequential: manager → privacy reviewer → Access request approvers → optional Access provider. "Only after the manager approves the request, the privacy reviewer if selected is notified." Statuses: Pending / Declined / Approved / Completed — with Approved and Completed deliberately separated because provisioning is a distinct step. Requesters track status under My data access; approvers work a Requests and approvals queue.

Honest limitation worth copying away from: "The product doesn't enforce policies such as attestations… The data consumer attests that they'll follow these policies." And revocation is two-step and error-prone — removing provisioning without deleting the request leaves the user with real access while the UI shows it removed.

1.5 Databricks Unity Catalog / Select Star — usage as documentation

Sources: https://www.databricks.com/blog/accelerating-discovery-unity-catalog-revamped-catalog-explorer · https://docs.selectstar.com/data-discovery/how-can-i-use-this-data

Databricks' revamped Catalog Explorer leads with Recents, Favorites and Popular, puts AI-generated comments in a right-hand metadata panel, extends lineage from 90 days to "all lineage in the past year" with monthly time-slices, and adds ER diagrams showing "primary key and foreign key relationships between tables."

Select Star goes furthest on behavioural metadata. A popularity score is "a metric that indicates how popular your data assets are amongst your team in terms of usage and activity" (service accounts filtered out). A Top Users tab names "people or accounts who run queries on the table the most." A Queries & Joins tab surfaces Popular Queries, Popular Joins ("tables that are most frequently joined to the current table") and Recent Queries. A Related tab separates Related Tables (used together in SELECT queries) from Similar Tables (similar structure). Column-level Field Usage labels each column "As Is," "Aggr," "Transformed," or "Filter."

[SYNTHESIS] This is the single most transferable idea for Spiff: for a non-technical user, "seventeen people in your region asked this question last month, and here's what they asked" is more trustworthy than any schema documentation. Social proof beats metadata.

1.6 Google Dataplex — quality as a catalog attribute

Source: https://docs.cloud.google.com/dataplex/docs/auto-data-quality-overview

Quality scan results publish back into the catalog under a data-quality-scorecard system aspect, showing "data quality scores" as rule pass percentages "at job, column, and dimension levels." Quality is not a separate tool; it is a field on the dataset.

---

2. The canonical dataset profile page

[SYNTHESIS] — an ordered inventory, composited from the above. Order is the argument: a non-technical user reads top-down and should be able to stop at any point with a defensible decision.

A. Identity band
1. Business name (plain English, not dim_mtg_attnd_f)
2. Technical name / alias, shown smaller
3. One-sentence purpose ("what question this answers")
4. Trust badge — Verified / Draft / Warning / Deprecated (four states, colour + icon + text)
5. Sensitivity badge — Public / Internal / Restricted / Personal
6. Domain / governance domain chip
7. Actions: Ask a question, Star, Copy link, Share, Request access, Report a problem

B. Trust and freshness strip
8. Last refreshed (relative + absolute), next expected refresh
9. Freshness status vs. SLA (on time / late / stale)
10. Quality score with dimension breakdown (completeness, validity, freshness, uniqueness)
11. Open incidents count, linked
12. Row count and its trend sparkline

C. Stewardship
13. Data owner (accountable) — name, photo, team, contact action
14. Data steward (day-to-day) — separate from owner
15. Subject-matter expert(s)
16. Escalation path / support channel
17. Certification date and who certified it

D. What's in it
18. Field list: business label, technical name, type, description, example value
19. Per-field sensitivity tag and masking state ("you see this hashed")
20. Per-field usage label (As Is / Aggregated / Transformed / Filter)
21. Per-field completeness %, distinct count, null rate
22. Linked glossary term per field
23. Search-within-fields

E. Sample data — first N rows, rendered under the viewer's own policies, with an explicit banner naming what is masked and why. [SYNTHESIS] This is where Spiff's "runs as its owner" invariant becomes visible rather than asserted.

F. Scope and coverage
24. Grain statement ("one row per person per meeting")
25. Time coverage (earliest/latest), geographic/regional coverage
26. Known exclusions and caveats, in prose
27. Population definition (who is in scope, who is not)

G. Rules in force — the list of governance rules applying to this dataset for this viewer: masking, row filters, suppression thresholds, retention. Each links to the rule object.

H. How people use it
28. Popularity score and rank within domain
29. Top users (with a "people like you" filter — same region/role)
30. Popular questions asked of it
31. Popular joins / commonly combined datasets

32. Saved answers and automations built on it

I. Lineage — upstream sources and downstream consumers, business-level by default with a technical toggle; column-level on demand.

J. Documentation — README/rich text, linked policy documents, FAQ, glossary terms.

K. Access
33. Your current access level, stated plainly
34. Who else has access (count + roles, not necessarily names)
35. Request access CTA with purpose selection
36. Your request history for this asset

L. Activity / changelog — schema changes, description edits, certification changes, rule changes, with actor and timestamp.

---

3. Semantic layers — one agreed definition

dbt Semantic Layer (https://docs.getdbt.com/docs/build/metricflow-commands) separates semantic models (entities, dimensions, measures) from metrics. A metric carries name, label, description, type (simple, ratio, cumulative, derived), type_params, filter, and meta. Governance is code-shaped: dbt sl validate performs semantic validation, dbt parse regenerates semantic_manifest.json, and versioning is automatic.

Cube (https://docs.cube.dev/reference/data-modeling/measures) defines a measure with name ("must be unique among all measures, dimensions, and segments"), sql, type, title, description, format, filters, rolling_window, drill_members, meta, and public — where public: false means the measure "cannot be queried through the API." Note meta.ai_context: an explicit slot for telling an AI agent how to use the metric.

Looker enforces the same idea through LookML, with access_grant and access_filter restricting explores, fields and rows by user attribute — i.e. the definition is shared but the result set is per-viewer. That is precisely Spiff's invariant, already proven in a shipping product.

[SYNTHESIS] The design lesson: a metric is a governed object with an owner and a label, not a formula. Non-technical users need label, description, owner, and "last agreed on <date> by <person>" far more than they need the SQL — but the SQL must be one click away, or trust collapses.

---

4. Data quality — what a rule looks like as a UI object

Monte Carlo (https://docs.getmontecarlo.com/docs/monitors-overview) groups monitors into Table, Metric, Validation, Job and Agent monitors, plus JSON Schema and Comparison. Every monitor carries Priority ("How urgent this monitor's alerts are"), Audience (who gets notified), Tags ("Free-form key/value labels for reporting, data contracts, team ownership") and a Data Quality Dimension — Accuracy, Completeness, Consistency, Timeliness, Validity, or Uniqueness. Accounts can require any combination of these at creation time: governance enforced through form validation.

Dataplex (https://docs.cloud.google.com/dataplex/docs/auto-data-quality-overview) offers row-level built-ins — RangeExpectation, NonNullExpectation, SetExpectation, RegexExpectation — and aggregate built-ins Uniqueness and StatisticRangeExpectation, plus three custom-SQL forms (row condition, table condition, SQL assertion). Every rule must be tagged with one of seven dimensions: Freshness, Completeness, Validity, Consistency, Accuracy, Uniqueness, Volume. Row-level rules take a "Passing threshold percentage."

Great Expectations contributes mostly — a tolerance parameter meaning "this rule passes if ≥ N% of rows satisfy it." Real-world rules are rarely absolute, and the UI should say so.

Immuta is the most directly relevant, because its policy builder is a natural-language sentence with dropdowns (https://documentation.immuta.com/SaaS/govern/secure-your-data/authoring-policies-in-secure/data-policies/reference-guides/data-policies):

> "Mask columns tagged [TAG] using [METHOD] for everyone except [EXCEPTION]."
> "Only show rows where [CONDITION] for everyone except [EXCEPTION]."
> "Only show data by [TIME_RANGE] for everyone except [EXCEPTION]."

Masking methods: Hashing ("irreversible sha256 hash, which is consistent for the same value throughout the data source"), NULL, Constant, Regex, Rounding ("Reduce, round, or truncate numeric or datetime values to a fixed precision"), Format Preserving Masking, Randomized Response, Reversible Masking, Custom Function, and Cell-Level Masking ("Conditionally masks the content in one column based on the value in another column of the same row"). Conflict resolution is explicit and teachable: masking conflicts "resolve hierarchically — deeper tag hierarchies override shallower ones (e.g. PII.SSN supersedes PII)"; equal depth defaults to earliest-authored; row-level policies merge with AND; reveal exceptions merge with OR.

Camunda DMN (https://docs.camunda.io/docs/components/modeler/dmn/decision-table-hit-policy/) gives the non-engineer authoring grammar: input columns, output columns, rules as rows, annotations, and an explicit hit policy — Unique ("Only a single rule can be satisfied or no rule at all"), Any (multiple may match but "all satisfied rules must generate the same output"), First, Rule order, Collect (with SUM/MIN/MAX/COUNT aggregators). Making "what happens when two rules match?" a visible, named, single-letter setting is the single best idea in the decision-table tradition.

---

5. The canonical business rule object

[SYNTHESIS] Every field a configurable Spiff rule needs:

Field	Purpose
Rule ID	Stable reference, quotable in an audit
Name	Human, imperative ("Mask member email outside own locality")
Plain-English statement	The Immuta sentence — the primary representation
Category	Masking / Row filter / Suppression / Retention / Metric definition / Consent
Quality dimension or governance dimension	Privacy, Safeguarding, Accuracy, Retention
Scope	Datasets, fields, domains, or tags the rule binds to
Condition	Structured predicate, rendered as if/then
Exception clause	"for everyone except…" — groups, attributes, roles
Action	Mask (method), filter, suppress, round, block, warn, annotate
Severity	Block / Redact silently / Redact with notice / Warn / Log only
Precedence	Explicit rank + hit policy for overlaps
Owner (accountable)	A named person, not a team inbox
Approver(s)	Who signed it off, and when
Status	Draft / In review / Active / Suspended / Retired
Effective from / to	Time-bound rules expire rather than rot
Legal or policy basis	Link to the actual policy document
Last run / evaluations today	Proves it is alive
Pass rate / rows affected	Proves it is doing something
Test & preview	"Show me what Sarah in Region 4 would see"
Change history	Who edited, what changed, why
Linked incidents	Where it fired and something broke

Example rules — religious-community / member-management domain

1. Mask member email and mobile outside own locality. Mask columns tagged Contact.Direct using Hashing for everyone except users whose locality matches the row's locality, or who hold the Regional Coordinator role. Severity: redact with notice.
2. Minors are name-only. Only show columns tagged Member.Detail where date_of_birth <= today - 18 years, for everyone except users holding Safeguarding Lead. Under-18 rows return name and locality only. Severity: block.
3. No date of birth for minors, ever. Mask date_of_birth using Rounding (to year) where age < 18 for everyone, with no exception clause. Severity: block; not overridable.
4. Deceased members: 24-month tail then archive. Only show rows where deceased_date is null OR deceased_date > today - 24 months for everyone except Records Office. Severity: filter.
5. Deceased members excluded from attendance rates. Metric definition: attendance_rate excludes members with deceased_date <= period_end from the denominator. Owner: Head of Statistics. Category: metric definition.
6. Small-count suppression on any member breakdown. Suppress any cell where count < 5; show "<5" rather than a number. Applies to all cross-tabs of member attributes. Severity: redact with notice.
7. Secondary suppression on totals. Where primary suppression is applied, suppress the next-smallest cell in the same row and column so the value cannot be derived by subtraction. Precedence: runs after rule 6.
8. Round locality-level attendance counts to base 5. Rounding applied to attendance_count at locality grain and below, for everyone except National Statistics.
9. Region scoping — default deny. Only show rows where region is in the viewer's assigned_regions attribute, for everyone except National Office. Precedence: highest; merges with AND against every other row filter.
10. Travel bookings: no passport or document numbers. Mask columns tagged Identity.Document using NULL for everyone except Travel Office during an active booking window. Severity: block.
11. Travel bookings visible only ±30 days of travel. Only show data by travel_date between today - 30 days and today + 30 days for everyone except Travel Office. Category: time-based restriction.
12. Pastoral notes are never queryable. Any field tagged Pastoral.Confidential is excluded from Spiff entirely — not masked, not listed. Severity: block; the field does not appear in the field list.
13. Attendance definition is single-sourced. "Attendance" = a member with a confirmed check-in record at a meeting of type Regular or Special; excludes Cancelled meetings and duplicate check-ins within 4 hours. Owner: Head of Statistics; version 3, agreed 2026-04-12. Category: metric definition.
14. Membership status uses the point-in-time value. active_member is evaluated as at the reporting period end, not as at query time, so historic reports do not drift.
15. Event registrations: dietary and accessibility notes are health-adjacent. Mask columns tagged Wellbeing using Constant ("[withheld]") for everyone except Event Operations with an active event assignment. Severity: redact with notice.
16. Retention: registration data purged 13 months after event close. Rows with event_end_date < today - 13 months are excluded from all query surfaces. Category: retention; effective from 2026-01-01.
17. Consent respected on outreach fields. Only show rows where contact_consent = true for any question grouped by or filtered on contact channel. No exception clause.
18. Cross-locality aggregate is allowed, cross-locality detail is not. A viewer outside a locality may see counts and rates for that locality (subject to rules 6–8) but zero member-level rows. Precedence: evaluated after region scoping; the aggregate exception is explicit, not implied.

---

6. Access governance at scale: UI patterns

Drawn from Entra ID Governance (https://learn.microsoft.com/en-us/entra/id-governance/entitlement-management-overview), SailPoint IdentityIQ (https://documentation.sailpoint.com/identityiq/help/certifications_and_access_reviews/access_review_decisions_operations.html) and Okta IG (https://help.okta.com/oie/en-us/content/topics/identity-governance/iga.htm).

Bundle, don't itemise. Entra's access package is "A bundle of all the resources with the access an identity needs to work on a project or perform their task," held in a catalog, governed by a policy that defines "who can approve, and how long they have access." Nobody at scale grants table-by-table. Spiff's equivalent is a named role bundle — "Locality Secretary," "Regional Statistics" — not a permission matrix.

Delegate the catalogue, not the admin console. Entra's Catalog Creator role lets a non-administrator create a catalog and automatically own it, then add co-owners and access package managers. Regional leaders should be able to run their own access without IT.

Time-bound by default. Entra: "ensure identities don't retain access indefinitely through time-limited assignments and recurring access reviews," with automatic removal on expiry. Every grant in Spiff should have an end date pre-filled.

Attribute-driven auto-assignment. Entra assigns "based on identity properties like department or cost center, and remove an identity's access when those properties change." For Spiff: access follows the locality/role record, and revokes when someone's role changes.

Sequential, staged approval with visible stage. Purview's manager → privacy reviewer → approver → access provider chain, with only one approver per stage needing to act, and expiry-not-escalation as the failure mode ("the request expires after the configured request duration"). Show the requester which stage they are in.

A single approvals queue, in the tool people already use. Entra: myaccess.microsoft.com → Approvals → Pending tab; each Request details panel shows "who made the request, and whether it was for themselves or for someone else," the requester's organisation, "access start and end date if provided," when submitted, when it expires, and the requester's justification at the bottom of the panel. Okta additionally routes requests through Slack/Teams.

Reviews as campaigns, with real verbs. SailPoint's reviewer decisions are Reassign, Approve, Delegate, Allow Exception (temporary access with an expiration date), Revoke or Edit Access, Revoke Account, Allow Violation, and Respond to Challenged Revocation. There is a Decisions tab, a percentage complete bar, bulk reassignment and bulk approval, and a mandatory Sign Off that cannot happen until every item is decided. Comments are retained with the item.

Patterns for hundreds of users [SYNTHESIS]:
- Default to role-and-attribute grants; treat individual exceptions as debt with an expiry.
- Give reviewers a pre-sorted queue: unusual access first, dormant access second, standard-for-role last, with a one-click "approve all standard-for-role."
- Show change since last review, not the full list — the diff is the reviewable unit.
- Progress bar + can't-sign-off-until-complete converts a chore into a finite task.
- Bulk-select with a mandatory reason on any revoke.
- Surface "who else like me has this" so a reviewer can judge normality at a glance.
- A matrix view (users × resources, colour-coded) for scanning; a list view for acting. Never make the matrix the primary edit surface — it invites mis-clicks at scale.
- Dormancy signals: "granted 14 months ago, never used" is the highest-value column on any review screen.
- Simulation before commit: "this change removes access for 47 people — preview them."

---

7. Design lessons

1. Trust needs four states, not two. Verified / Draft / Warning / Deprecated. Alation's

split of warning from deprecation is the one most products get wrong.
2. Write rules as sentences. Immuta's "Mask columns tagged X using Y for everyone except Z" is readable by a non-engineer and executable by a machine. Build the rule editor as a sentence with dropdowns, not a form with fields.
3. Name the hit policy. Overlapping rules are inevitable; DMN makes precedence a visible, named setting. Show the user which rule won and why.
4. Usage is the best documentation. Popularity, top users, popular questions and popular joins tell a non-technical user more than a data dictionary ever will.
5. Put requests on the object. Atlan's Requests tab means asking happens in context and the history stays attached to the thing being asked about.
6. Separate Approved from Completed. Purview's four statuses exist because provisioning is a real step that fails. Never let a UI claim access the user does not have.
7. Purpose is a required field. Collibra and Purview both force a stated business purpose. It is cheap to collect, and it is the field auditors actually read.
8. Ownership is a person. Owner, steward and SME are three different roles; show faces and a contact action, not a mailbox.
9. Render the sample data under the viewer's own policies. A masked preview is the most persuasive possible demonstration of "runs as you." Add a banner naming what was hidden.
10. Tolerance is normal. Great Expectations' mostly and Dataplex's "passing threshold percentage" acknowledge that real rules are ≥95%, not 100%. Rules that can't express tolerance get switched off.
11. Rules need a test harness. "Show me what Sarah in Region 4 would see" must be one click from the rule editor, or nobody will change a rule after the first week.
12. Every grant expires. Pre-fill an end date. Renewal is a smaller conversation than revocation.
13. Review the diff, not the list. At hundreds of users, the reviewable unit is what changed since last time.
14. Bundle access into named roles. "Locality Secretary" scales; a permission matrix does not.
15. Suppression must be explicit and explained. "<5" with a hover saying why is trustworthy; a silently missing row is not. Follow the GSS pattern: primary suppression, then secondary suppression against derivation by subtraction, then rounding to a base (https://gss.civilservice.gov.uk/wp-content/uploads/2018/03/Guidance-for-tables-produced-from-administrative-sources-4.pdf).
16. Governance metadata can be enforced at creation. Monte Carlo lets an account require priority, audience, owner and dimension before a monitor can be saved. Make the form the policy.

Sources

- https://docs.atlan.com/product/capabilities/discovery/concepts/what-are-asset-profiles
- https://docs.atlan.com/product/capabilities/governance/access-control/concepts/what-are-personas
- https://productresources.collibra.com/docs/collibra/latest/Content/Catalog/DataSets/ta_request-access-to-data-set.htm
- https://docs.alation.com/en/latest/welcome/BestPractices/UseTrustFlagstoProceedwithConfidence.html
- https://learn.microsoft.com/en-us/purview/unified-catalog-data-products
- https://learn.microsoft.com/en-us/purview/unified-catalog-data-product-access-policies
- https://www.databricks.com/blog/accelerating-discovery-unity-catalog-revamped-catalog-explorer
- https://docs.selectstar.com/data-discovery/how-can-i-use-this-data
- https://docs.cloud.google.com/dataplex/docs/auto-data-quality-overview
- https://docs.getdbt.com/docs/build/metricflow-commands
- https://docs.cube.dev/reference/data-modeling/measures
- https://docs.getmontecarlo.com/docs/monitors-overview

- https://docs.greatexpectations.io/docs/reference/learn/terms/expectation/
- https://documentation.immuta.com/SaaS/govern/secure-your-data/authoring-policies-in-secure/data-policies/reference-guides/data-policies
- https://documentation.immuta.com/SaaS/govern/secure-your-data/authoring-policies-in-secure/data-policies/reference-guides/masking-matrix-functions
- https://docs.camunda.io/docs/components/modeler/dmn/decision-table-hit-policy/
- https://learn.microsoft.com/en-us/entra/id-governance/entitlement-management-overview
- https://learn.microsoft.com/en-us/entra/id-governance/entitlement-management-request-approve
- https://documentation.sailpoint.com/identityiq/help/certifications_and_access_reviews/access_review_decisions_operations.html
- https://help.okta.com/oie/en-us/content/topics/identity-governance/iga.htm
- https://gss.civilservice.gov.uk/wp-content/uploads/2018/03/Guidance-for-tables-produced-from-administrative-sources-4.pdf